

Manual keys runbook

The three remaining provider signups. Everything is pre-staged so this should be 20 minutes total: 10 for Plaid, 5 for Google Places, 5 to kick off Google OAuth verification (Google's review then runs in the background for 4-6 weeks).

When you finish each provider, paste the keys to me in chat in the exact format at the bottom of each section. I'll set the Vercel env vars and trigger a redeploy in one shot.

1. Plaid sandbox (10 min, biggest unblock)

The integration code is already shipped behind these env vars: `PLAID_CLIENT_ID`, `PLAID_SECRET`, `PLAID_ENV`, optionally `PLAID_WEBHOOK_URL` and `PLAID_REDIRECT_URI`, plus `BANK_TOKEN_ENC_KEY` for at-rest encryption of the per-Item access tokens (required - the exchange route refuses to write a connection without it). The "Connect a bank" button on `/c/[publicId]/banks` lights up the moment they're all set.

Generating BANK_TOKEN_ENC_KEY

Run this once and save the output somewhere durable (1Password, Bitwarden, etc.). Losing the key means every existing connection becomes unusable - the access tokens can't be decrypted. Rotation is a separate runbook entry.

```
openssl rand -base64 32
```

Paste the resulting 44-character base64 string when you send the Plaid keys.

Click track

1. <https://dashboard.plaid.com/signup>
2. Sign up with your work email. Country: United States. Use case: pick **Personal finance / budgeting**. Industry: **Software / internet**.
3. After login, top-left environment dropdown set to **Sandbox**.
4. **Team Settings** → **Keys**. Copy:
 - `client_id`
 - The Sandbox row's `secret` (NOT Development or Production)
5. **Team Settings** → **API** → **Allowed redirect URIs**. Add (one per line):

```
https://taxottic.com/api/banks/plaid/oauth-return
https://www.taxottic.com/api/banks/plaid/oauth-return
```

Save. (These cover OAuth-flow institutions like Chase. Without them, Chase / Capital One / etc. will fail in Plaid Link.)

6. **Team Settings** → **API** → **Webhooks**. Add:

```
https://taxottic.com/api/banks/plaid/webhook
```

Save.

7. (Optional) **Team Settings** → **Compliance**. Fill out the company name (Techno Optics LLC), address, support email. This isn't required for sandbox but it's needed before you can request production access later.

What to paste me

```
PLAID_CLIENT_ID=<value from step 4>
PLAID_SECRET=<sandbox value from step 4>
BANK_TOKEN_ENC_KEY=<output of openssl rand -base64 32>
```

I'll add `PLAID_ENV=sandbox`, `PLAID_WEBHOOK_URL`, `PLAID_REDIRECT_URI`, and `PLAID_WEBHOOK_SKIP_VERIFY=1` for the sandbox window myself, then redeploy. (We turn webhook verification back on the moment we move to production - sandbox webhooks are signed too, so the skip flag is just a convenience for the short-lived test window.)

After deploy: smoke test

1. Open `https://taxottic.com/c/<your-company-public-id>/banks`
2. Click **Connect a bank**.
3. Plaid Link opens. Pick **Chase Bank** (any will do in sandbox).
4. Use sandbox creds: username `user_good`, password `pass_good`. MFA if asked: code `1234`.
5. Plaid Link closes. The page refreshes and the connection appears with 30 days of fake transactions. The pending-review counter on the hero card jumps to a non-zero number.

If the smoke test fails, send me the browser console errors plus the Vercel logs for `/api/banks/plaid/exchange` and I'll debug.

2. Google Places API key (5 min, optional polish)

Without this, the "Find a CPA" card shows a Google Maps search link (works, but generic). With it, you get an inline list of nearby tax preparers ranked by Google review score and live distance.

Click track

1. <https://console.cloud.google.com/projectselector2/apis/dashboard>
2. If you already have a `taxottic-prod` (or similar) project for the existing OAuth client, use that. Otherwise click **New Project**:
 - Name: `taxottic-prod`
 - Organization: leave default
 - Click **Create**. Wait 10 seconds for it to provision.
3. Top bar **Project selector** → switch to the project from step 2.
4. **APIs & Services** → **Library**. Search **Places API (New)**. Click **Enable**. (Confirm "Places API (New)", not the deprecated "Places API".)
5. Banking: Google forces a billing account on. Top-left hamburger → **Billing**. If you don't have one, click **Link billing account** → **Create billing account**. Add your card. Free tier: 10,000 essential calls / month, no charge unless exceeded.
6. **APIs & Services** → **Credentials** → **Create credentials** → **API key**. Copy the value.
7. Click the new key to edit:
 - **Application restrictions** → **HTTP referrers**. Add (each on its own line):

```
https://taxottic.com/*  
https://*.taxottic.com/*
```

- **API restrictions** → **Restrict key** → **Places API (New)**. Save.

What to paste me

```
GOOGLE_PLACES_API_KEY=<value from step 6>
```

I set the env var, redeploy, and the FindCpaCard switches from the fallback link to inline results.

3. Google OAuth verification (5 min to start, 4-6 weeks to finish)

This removes the "unverified app" warning that shows the first time a new user clicks **Continue with Google** on `/login`. Microsoft already passes consent without warning, and magic-link signups skip this entirely. Verification is high-leverage but not critical-path.

Click track

1. <https://console.cloud.google.com/apis/credentials/consent>
2. Pick the project that owns the OAuth client used by Supabase. That client_id starts with `957351998229-` (you can confirm by matching it against `Supabase Dashboard` → `Auth` → `Providers` → `Google`).

3. **OAuth consent screen** → **Edit App**. Paste these field-by-field:

App information

- App name: `Taxottic`
- User support email: pick yours from the dropdown
- App logo: upload `public/icon.svg` rasterized to a 120×120 PNG. If you don't have one, the existing favicon at `https://taxottic.com/favicon.ico` works (Google may auto-resize to spec). Either way, the logo must show on a non-transparent background.

App domain

- Application home page: `https://taxottic.com`
- Application privacy policy link: `https://taxottic.com/legal/privacy`
- Application terms of service link: `https://taxottic.com/legal/terms`

Authorized domains

- `taxottic.com` (just the apex - Google auto-allows subdomains)

Developer contact information

- Email addresses: yours

Click **Save and continue**.

4. **Scopes**. Click **Save and continue** without changing anything. The defaults are `openid`, `email`, `profile` - all non-sensitive, which keeps verification fast (a couple weeks instead of 6+).
5. **Test users**. Add 3-5 emails (yours, a personal Gmail, a couple teammate emails). Test users skip the warning even before verification, so this is your "demo account" path until Google approves.
6. **Summary** → **Back to dashboard**.
7. **Publishing status**: click **Publish App** → confirm. You're now in production but unverified.
8. Click **Submit for verification** (same panel). Fill the form:

App functionality (paste this verbatim):

```
Taxottic is a personal tax-forecasting SaaS for U.S. small
business owners and 1099 contractors. Google Sign-In is used
only for account authentication; we request the standard
openid/email/profile scopes to identify the user and pre-fill
their display name. We do not request, read, or store any
Google service data (no Drive, Gmail, Contacts, etc.). Sign-in
creates one row in our auth.users table; no Google data is
forwarded to third parties.
```

Why are you applying for verification?

To remove the "unverified app" warning shown to new users on first sign-in, which currently causes drop-off.

Demo video URL: see "Recording the demo video" below.

Click **Submit**.

Recording the demo video (3 minutes)

Google requires a screen recording showing the OAuth consent flow end to end. Use any screen recorder (QuickTime, OBS, the Windows Game Bar). Total length: ~60 seconds. Upload to YouTube as **Unlisted** and paste the link in the verification form.

Shot list:

1. **0:00-0:05** - Open `https://taxottic.com/login` in a fresh incognito window. Show the page. Narrate: "This is the Taxottic sign-in page."
2. **0:05-0:10** - Click **Continue with Google**.
3. **0:10-0:25** - On the Google account picker, choose an account that's **not** in your test-users list (so the "unverified app" warning shows - Google needs to see the warning being triggered in the unverified state). Click through the warning. Land on the consent screen showing `email`, `profile`, `openid`.
4. **0:25-0:30** - Click **Continue**.
5. **0:30-0:40** - Browser redirects to `https://taxottic.com/auth/callback` then to `/dashboard`. Show the dashboard rendering.
6. **0:40-0:55** - Click the user-menu avatar top-right, show **Sign out**. Narrate: "The user can sign out at any time, which ends our session."
7. **0:55-1:00** - End on the login page.

After submission

Google emails 2-4 weeks later. If they ask for changes, the form pre-fills your previous answers - just edit and resubmit. Most common request: a clearer explanation of why you need the scope (answer: "to identify the user across sessions; no third-party sharing"). They almost never reject for non-sensitive scopes.

What to paste me

Nothing. Verification doesn't change any keys. Once Google approves, the warning just disappears for all users - no redeploy required.

4. Plaid production access (when ready for real users)

Sandbox uses fake institutions only. Real bank linking requires Plaid to approve our application, which is a manual review of the privacy + security posture. Plaid's review queue is typically 5-10 business days but can stretch to 3-4 weeks during volume spikes. Submit this once you're satisfied with the sandbox flow.

The code-side prerequisites are already shipped:

- Access tokens are AES-256-GCM encrypted at rest (`lib/crypto/bankTokens.ts` , key in `BANK_TOKEN_ENC_KEY`).
- Webhooks verify the Plaid-Verification JWT against `/webhook_verification_key/get` JWKS, check the body SHA-256, and reject anything older than 5 minutes (`lib/plaid/webhookVerify.ts`).
- `/legal/privacy` , `/legal/terms` , `/legal/dpa` , and `/legal/security` are live.

Click track

1. <https://dashboard.plaid.com/team/compliance> — confirm the compliance form is filled out (company name "Techno Optics LLC", registered address, support email `support@taxottic.com` , privacy + ToS URLs as below). Sandbox doesn't enforce this; the production reviewer reads every field.
2. <https://dashboard.plaid.com/overview/production> → **Request production access**.
3. Application form. Paste these answers verbatim into the matching fields (Plaid renames fields between revisions, but the prompts are stable):

Company name:

Techno Optics LLC

Product name:

Taxottic

Website:

<https://taxottic.com>

Use case category: Personal finance / budgeting

Plaid products requested: Transactions only (Auth, Identity, Assets, etc. should all be unchecked - we do not need any of them and asking for unused products slows the review).

Country coverage: United States only.

Use-case description:

Taxottic forecasts U.S. federal and state tax liability for freelancers, 1099 contractors, and small-business owners. We read transaction history from the user's linked bank or card accounts (Plaid Transactions product) and match each posted transaction against a 1,025-item IRS deduction catalog (Pubs 334, 463, 535, 587, 946) to surface deductible expenses and keep a running quarterly safe-harbor estimate.

We never initiate transfers, never read auth/balance for payment, and never share or sell transaction data. The only network egress that touches Plaid data is (1) our database write path, (2) an internal LLM call that classifies a single transaction at a time without retaining the prompt, and (3) the user's own dashboard.

How is end-user data stored?

Postgres (Supabase managed, AWS us-east-1) with row-level security restricting reads to the company that linked the account. Plaid access_tokens are AES-256-GCM encrypted at rest in bank_connection_secrets.access_token_enc; the encryption key lives only in our server runtime env (Vercel). Database backups inherit AWS RDS at-rest encryption. Transactions are stored in account_transactions with the same RLS guard.

How is end-user data transmitted?

TLS 1.2+ on every hop. Plaid Link runs in the user's browser over HTTPS; the public_token returns to our HTTPS API route; the public_token -> access_token exchange and every transactions/sync call go server-to-server over HTTPS to production.plaid.com.

Webhook URL:

<https://taxottic.com/api/banks/plaid/webhook>

OAuth redirect URI:

<https://taxottic.com/api/banks/plaid/oauth-return>

Privacy policy URL: <https://taxottic.com/legal/privacy>

Terms of service URL: <https://taxottic.com/legal/terms>

DPA URL: <https://taxottic.com/legal/dpa>

Security overview URL: `https://taxottic.com/legal/security`

Estimated monthly Items at launch: start with 100 to keep the price tier honest; you can always raise it later from the dashboard.

4. **Demo video.** Plaid asks for a screen recording showing a real end-to-end link flow. Use the sandbox account (`user_good` / `pass_good` against any institution) and record:
- 0:00-0:10 - `https://taxottic.com/login` , sign in.
 - 0:10-0:20 - Navigate to `/c/<id>/banks` , click **Connect a bank**.
 - 0:20-0:50 - Plaid Link opens, pick Chase, type sandbox creds, click through the consent screens.
 - 0:50-1:00 - Land back on the banks page; show the connection appearing with imported transactions.

Upload as **YouTube Unlisted** and paste the link in the form. Total length 60-90 seconds is plenty.

5. Click **Submit for review**.

After submission

Plaid emails the team contact when they need anything. The two most common follow-ups:

- **"Confirm tokens are encrypted at rest"** - point them at `bank_connection_secrets.access_token_enc` and the AES-256-GCM helper in `lib/crypto/bankTokens.ts` .
- **"Confirm webhook signature verification"** - point them at `lib/plaid/webhookVerify.ts` . Plaid sometimes asks for a sample log line showing a 401 on a tampered request; toggle `PLAID_WEBHOOK_SKIP_VERIFY=0` (the default in production) and curl the endpoint with a dummy body.

What to paste me when approved

```
PLAID_SECRET=<production value from Team Settings -> Keys>
```

Everything else (`PLAID_CLIENT_ID` is the same across envs, `PLAID_ENV` flips to `production` , webhook + redirect URLs are already on the right hostnames) I switch on Vercel and redeploy. First production link should work immediately - no code changes needed.

After all three are in: smoke test

I'll batch these into one Vercel deploy. After it's READY, run this checklist:

- ☐ `taxottic.com/c/<id>/banks` → Connect a bank → sandbox creds `user_good` / `pass_good` → connection appears with 30 days of fake tx
- ☐ `taxottic.com/c/<id>` (any company page with a zip) → "Find a CPA" card shows inline list with star ratings and distance
- ☐ `taxottic.com/login` from an incognito window in a Google account in your test-users list → no "unverified app" warning (test users always skip it; the warning only goes away for everyone after

verification finalizes)